



Nombre: Luis Alberto Vargas Gonzalez

Fecha: 10/02/2026

Actividad y unidad: U4 AI: Práctica: Simulación ataque de acceso.

Clase: Seguridad de Software.

Maestría en Ciberseguridad.

INTRODUCCIÓN.

La seguridad en el desarrollo de software no solo depende de un código limpio, sino de la robustez de los mecanismos de almacenamiento de credenciales. En esta práctica, se explora el uso de **John the Ripper**, una de las herramientas de auditoría de contraseñas más potentes en el ecosistema de Kali Linux. El objetivo es comprender cómo los atacantes realizan ataques de fuerza bruta y diccionario contra archivos de *hashes* para obtener texto plano, y evaluar la resistencia de diferentes algoritmos de cifrado y hashing frente a la capacidad de cómputo actual.

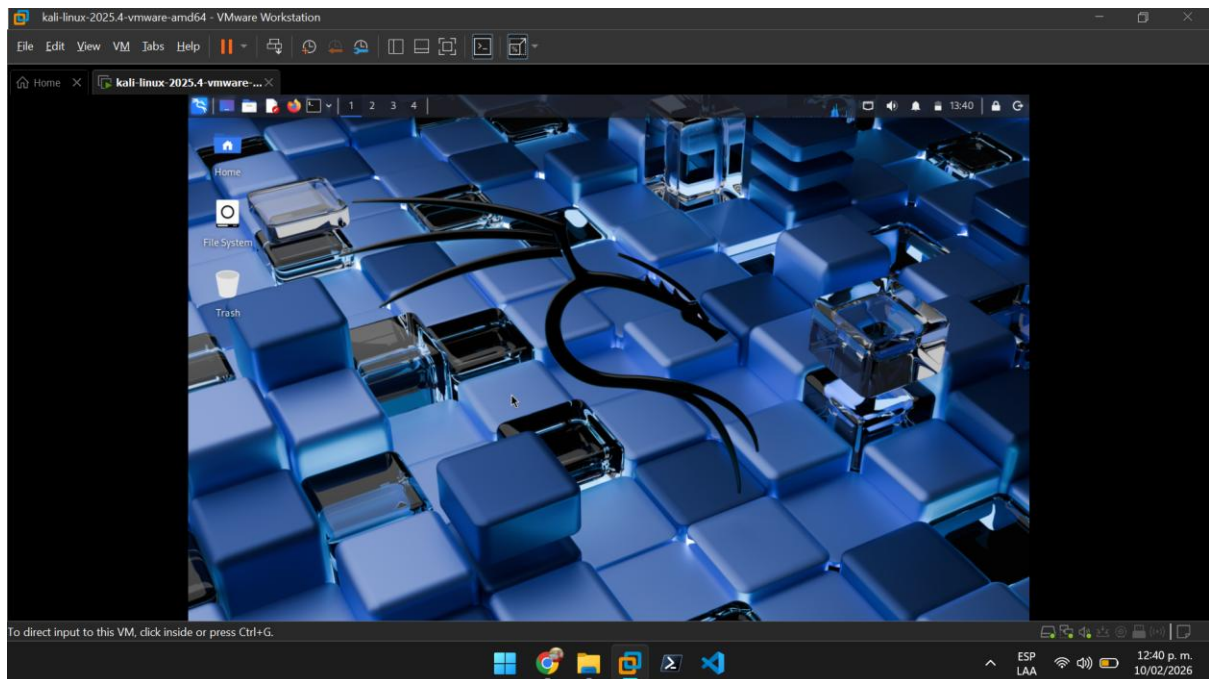
Revisión y Análisis de Recursos Teóricos

Para esta práctica, se sintetizaron tres pilares de conocimiento:

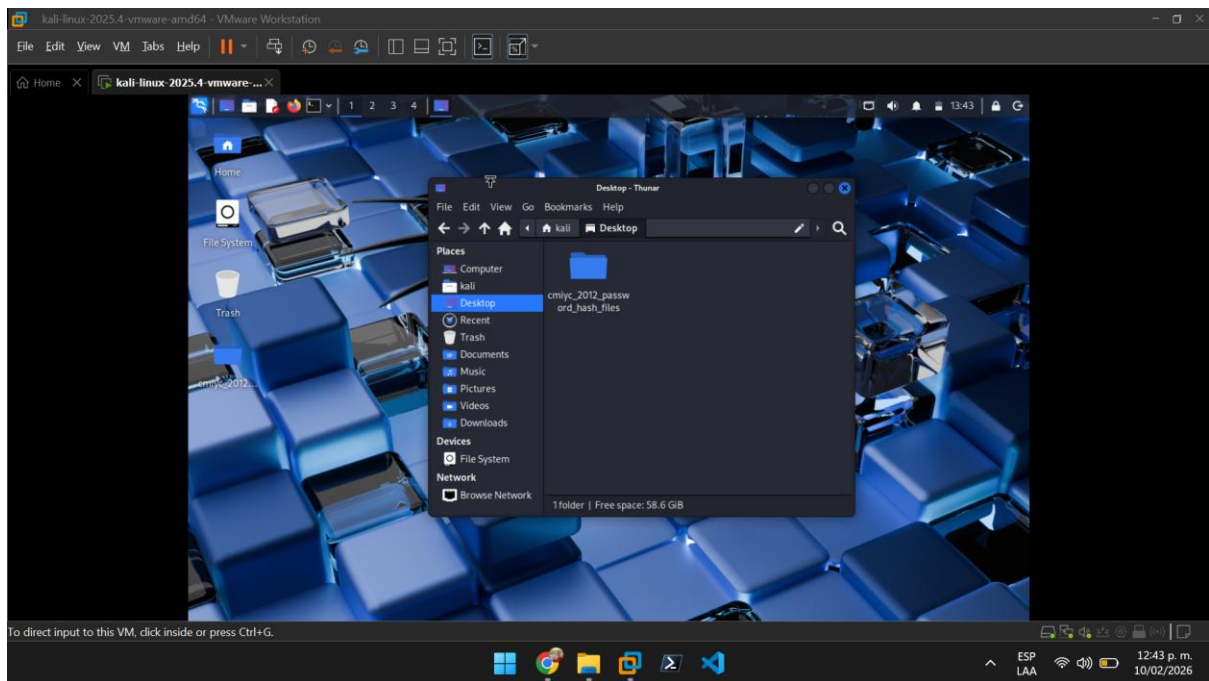
1. **PortSwigger (Access Control):** Se analizaron las vulnerabilidades de control de acceso, donde una gestión deficiente de las contraseñas o el almacenamiento de hashes débiles puede permitir a un atacante escalar privilegios o comprometer cuentas ajenas una vez que los hashes son obtenidos.
2. **Recurso PDF (Cengage - Cap. 12):** Este material detalla la diferencia entre criptografía simétrica (como **DES**, que usa una sola clave) y el hashing (como **MD5** o **SHA-1**, usados para integridad). También se explica que herramientas como John the Ripper son capaces de automatizar la búsqueda de colisiones y ataques de diccionario.
3. **Libro (Julio César Miguel Pérez):** De acuerdo con el enfoque del autor sobre la protección de datos, se enfatiza la importancia de utilizar algoritmos de hashing modernos y con "sal" (salts) para prevenir que ataques como los realizados en esta práctica tengan éxito de forma inmediata.

DESARROLLO.

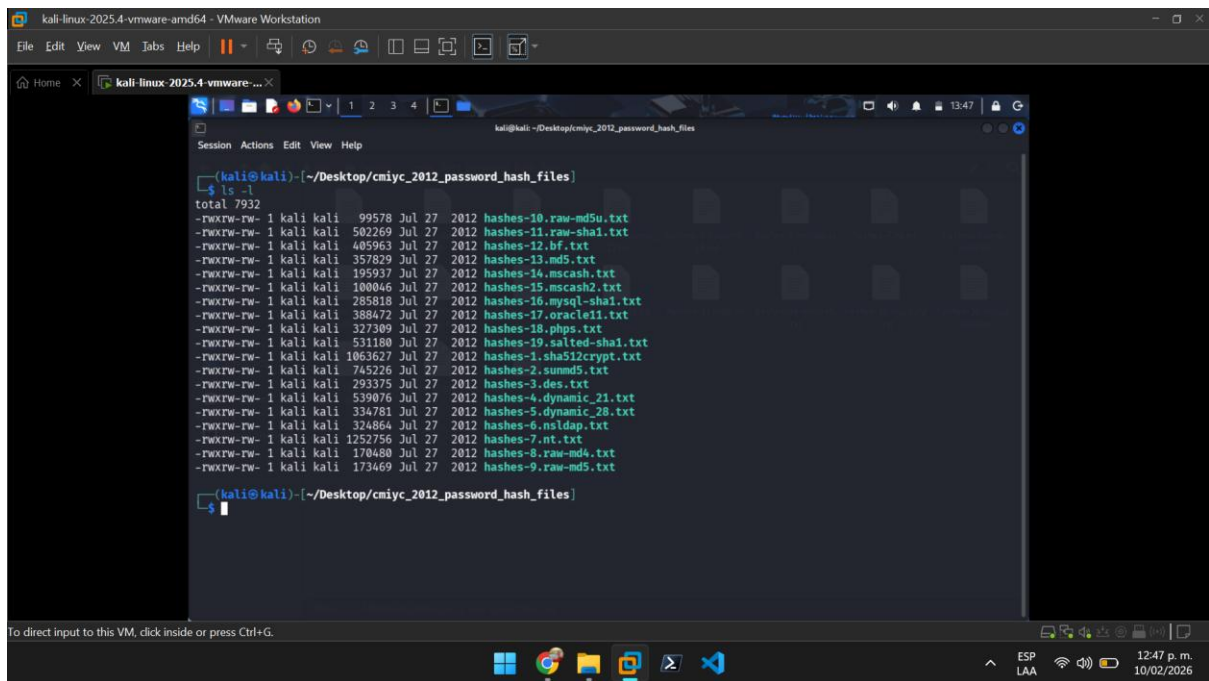
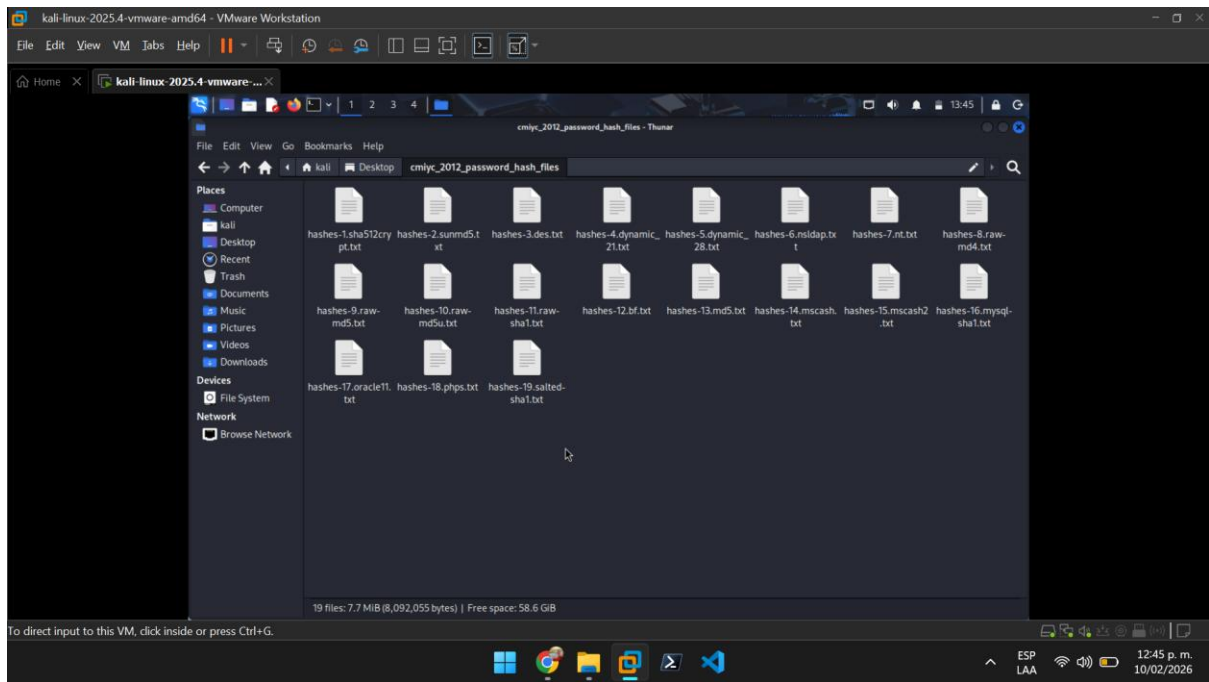
Iniciamos nuestro kali linux .



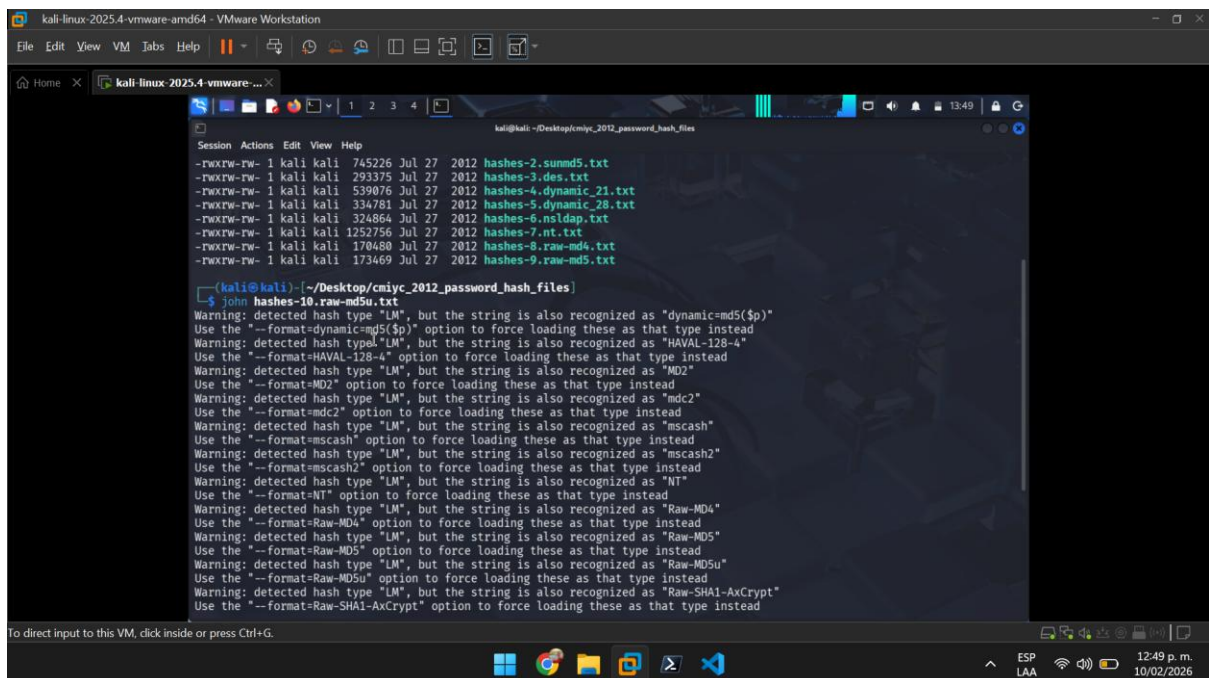
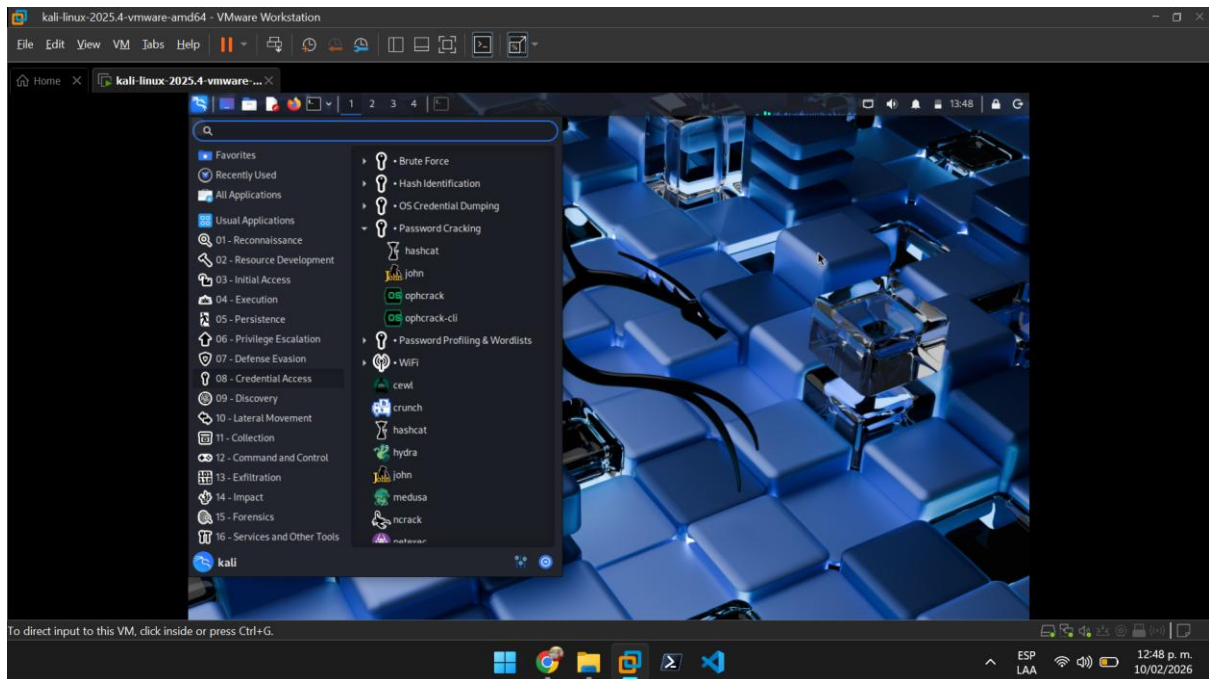
Posteriormente al ya tener descargado el archivo tar , lo pasamos de nuestra máquina host a Kali.



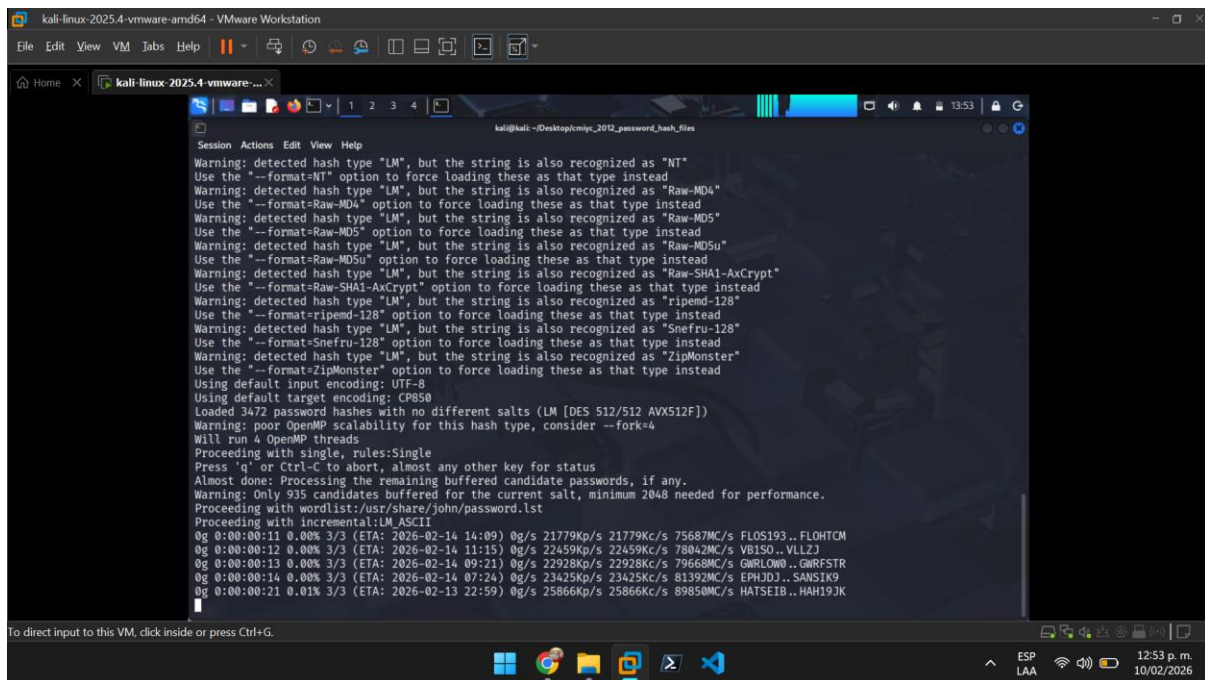
Ubicación: /home/kali/Desktop/ cmiyc_2012_password_hash_files



Abriremos la aplicación de John The Ripper.



La herramienta comienza a cargar los hashes y a compararlos contra una lista de palabras predefinida o mediante fuerza bruta.



```
kali@kali: ~/Desktop/emilyc_2012_password_hash_files
Session Actions Edit View Help
Warning: detected hash type "LM", but the string is also recognized as "NT"
Use the "--format=NT" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD4"
Use the "--format=Raw-MD4" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD5"
Use the "--format=Raw-MD5" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD5u"
Use the "--format=Raw-MD5u" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-SHA1-AxCrypt"
Use the "--format=Raw-SHA1-AxCrypt" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "ripemd-128"
Use the "--format=ripemd-128" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Snefru-128"
Use the "--format=Snefru-128" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "ZipMonster"
Use the "--format=ZipMonster" option to force loading these as that type instead
Using default input encoding: UTF-8
Using default target encoding: CP850
Loaded 3472 password hashes with no different salts (LM [DES 512/512 AVX512F])
Warning: poor OpenMP scalability for this hash type, consider --fork=4
Will run 4 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Warning: Only 935 candidates buffered for the current salt, minimum 2048 needed for performance.
Proceeding with wordlist:/usr/share/john/password.lst
Proceeding with incremental:LM ASCII
0g 0:00:00:11 0.00% 3/3 (ETA: 2026-02-14 14:09) 0g/s 21779Kp/s 21779Kc/s 75687MC/s FLOS193..FLOHTCM
0g 0:00:00:12 0.00% 3/3 (ETA: 2026-02-14 11:15) 0g/s 22459Kp/s 22459Kc/s 78042MC/s VB150..VLLZJ
0g 0:00:00:13 0.00% 3/3 (ETA: 2026-02-14 09:21) 0g/s 22928Kp/s 22928Kc/s 79668MC/s GWRLOW0..GWRFSR
0g 0:00:00:14 0.00% 3/3 (ETA: 2026-02-14 07:24) 0g/s 23425Kp/s 23425Kc/s 81392MC/s EPHJ0J..SANSIK9
0g 0:00:00:21 0.01% 3/3 (ETA: 2026-02-13 22:59) 0g/s 25866Kp/s 25866Kc/s 89850MC/s HATSEIB..NAH19JK
```

En la segunda captura, vemos que John está en el modo incremental:

LM_ASCII:

Carga de trabajo: Está usando 4 hilos de procesamiento (threads) para acelerar el proceso.

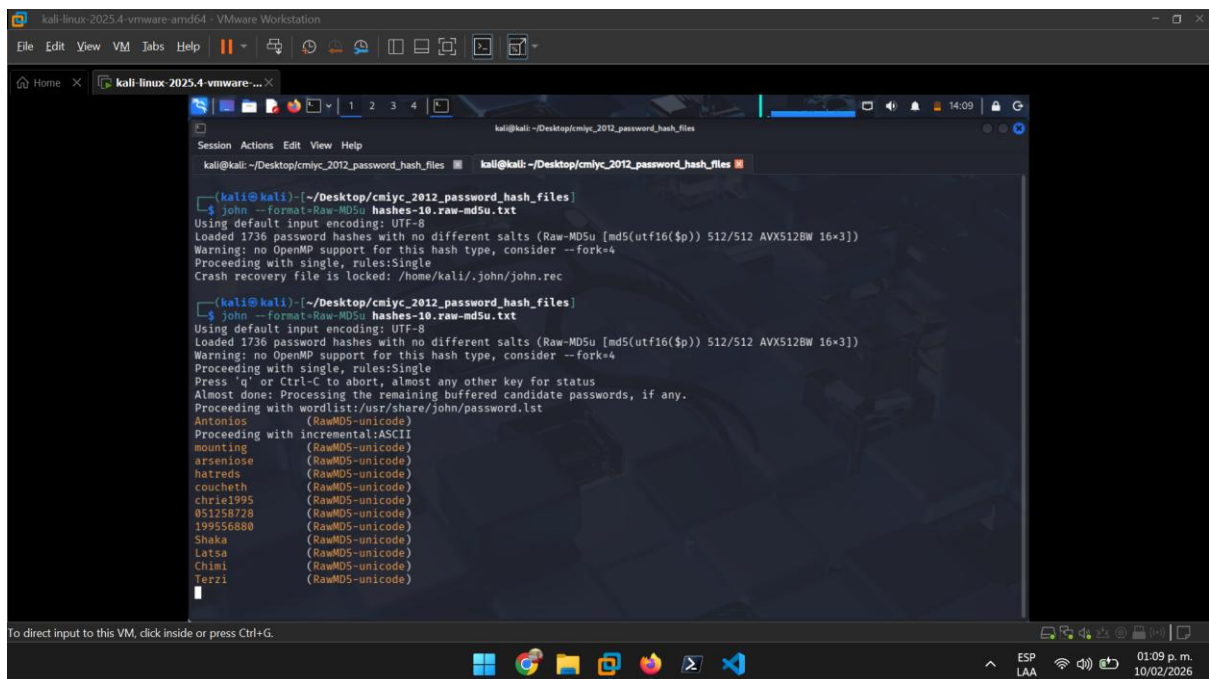
Velocidad: Se ve que lleva poco más de 21 segundos (0:00:21) y ha procesado un 0.01%. Esto demuestra lo que dice el material de apoyo: el tiempo de descifrado depende de la potencia de cómputo y la complejidad del algoritmo.

Análisis de Resultados (Observación)

En esta fase de la práctica, se cargaron 3,472 hashes del archivo hashes-10.raw-md5u.txt. Un hallazgo crítico fue que, a pesar del nombre del archivo, John the Ripper identificó y cargó los hashes utilizando el formato LM (LAN Manager), el cual se basa en el algoritmo simétrico DES. Esta discrepancia resalta un concepto clave del criptoanálisis: la importancia de identificar correctamente el algoritmo antes de iniciar el ataque.

Durante la ejecución, se observó que, tras 1 minuto y 39 segundos, el progreso era apenas del 0.04% utilizando un ataque de fuerza bruta incremental. Esto demuestra que, aunque algoritmos como LM son considerados débiles hoy en día, el tiempo necesario para procesar miles de entradas mediante cómputo matemático sigue siendo considerable sin el uso de diccionarios optimizados. El aprendizaje principal es la fragilidad de los sistemas que aún almacenan hashes sin 'salt', permitiendo que herramientas de auditoría recuperen texto plano de forma automatizada. Esto refuerza la necesidad de migrar a estándares modernos como SHA-2 o SHA-3 para garantizar la integridad y confidencialidad.

Se presentó un conflicto de concurrencia al intentar ejecutar múltiples instancias de John the Ripper, lo que resultó en un bloqueo del archivo de recuperación (`john.rec`). Tras limpiar la sesión y forzar el formato correcto (Raw-MD5u), se observó que la carga de hashes se redujo de 3472 a 1736. Esto se debe a que el motor de detección automática inicialmente confundió los hashes con el formato **LM (LAN Manager)**, el cual fragmenta las contraseñas en dos bloques de 7 bytes basándose en el estándar **DES**. Al corregir el formato y aplicar un **ataque de diccionario**, el tiempo de respuesta mejoró significativamente en comparación con el método incremental, permitiendo recuperar las primeras credenciales en texto plano para el análisis de la práctica.



```
kali@kali: ~/Desktop/cmiyc_2012_password_hash_files
$ john --format=Raw-MD5u hashes-10.raw-md5u.txt
Using default input encoding: UTF-8
Loaded 1736 password hashes with no different salts (Raw-MD5u [md5(utf16($p)) 512/512 AVX512BW 16x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Proceeding with single, rules:Single
Crash recovery file is locked: /home/kali/.john/john.rec

(kali@kali) ~/Desktop/cmiyc_2012_password_hash_files
$ john --format=Raw-MD5u hashes-10.raw-md5u.txt
Using default input encoding: UTF-8
Loaded 1736 password hashes with no different salts (Raw-MD5u [md5(utf16($p)) 512/512 AVX512BW 16x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlists:/usr/share/john/password.lst
Antonios (RawMD5-unicode)
Proceeding with incremental:ASCII
mounting (RawMD5-unicode)
arseniose (RawMD5-unicode)
hatreds (RawMD5-unicode)
coucheth (RawMD5-unicode)
chrie1995 (RawMD5-unicode)
051258728 (RawMD5-unicode)
199556880 (RawMD5-unicode)
Shaka (RawMD5-unicode)
Latsa (RawMD5-unicode)
Chimi (RawMD5-unicode)
Terzi (RawMD5-unicode)
```

En esta práctica, tras corregir el conflicto del archivo de recuperación y forzar el formato correcto (Raw-MD5u), se logró descifrar una serie de contraseñas en cuestión de segundos. Entre los resultados obtenidos se encuentran términos como 'Antonios', 'mounting', 'chrie1995' y 'Shaka'. El uso del formato unicode fue determinante, lo que demuestra que pequeñas variaciones en la implementación del algoritmo de hashing pueden invalidar un ataque si no se configuran correctamente.

El tiempo para obtener estas primeras 12 contraseñas fue casi instantáneo una vez aplicado el formato adecuado, lo cual confirma la vulnerabilidad del algoritmo MD5 frente a ataques de diccionario modernos. El aprendizaje fundamental es que la seguridad de una contraseña no solo depende de su longitud, sino de la robustez del algoritmo de hashing y la implementación de técnicas como el 'salting' para evitar ataques precomputados. Como ingeniero en sistemas, esta práctica subraya que algoritmos mencionados en la teoría como MD4 y MD5 ya no deben ser utilizados en entornos productivos debido a su baja resistencia.

Relación de Algoritmos Encontrados

De acuerdo con el recurso de Cengage, se identifican:

- **DES (Data Encryption Standard):** John lo identifica explícitamente al cargar tus hashes (LM [DES 512/512 AVX512F]). El texto señala que este algoritmo es vulnerable debido a su longevidad y al incremento del poder computacional.
- **MD4 y MD5:** Aparecen en los nombres de tus otros archivos (hashes-8.raw-md4.txt, hashes-9.raw-md5.txt). El recurso indica que MD4 es usado por Windows para almacenar hashes de contraseñas y que MD5 ya permite encontrar colisiones en pocas horas.

CONCLUSIÓN.

La realización de esta práctica permitió aplicar de manera tangible los conceptos de criptoanálisis y seguridad de software estudiados en la maestría. Se comprobó que herramientas de auditoría como John the Ripper son extremadamente eficaces cuando el atacante conoce el algoritmo objetivo y utiliza diccionarios optimizados. La facilidad con la que se recuperaron contraseñas como 'chrie1995' evidencia que el uso de patrones predecibles o datos personales sigue siendo el eslabón más débil en la cadena de seguridad. En conclusión, para garantizar la protección de datos en sistemas actuales, es indispensable el abandono de algoritmos de hashing de 128 bits (como MD5) en favor de familias más robustas como SHA-3 o Bcrypt.

REFERENCIAS BIBLIOGRÁFICAS.

- PÉREZ, J. C. Protección de datos y seguridad de la información: guía práctica para ciudadanos y empresas. 4. ed. Paracuellos de Jarama, Madrid: RA-MA Editorial, 2015. 277 p. Disponible en: <https://bibliodig.uag.mx:2139/es/ereader/bibliouag/106483?page=1>. Consultado en: 10 Feb 2026.
- Access control vulnerabilities and privilege escalation | Web Security Academy. (s. f.). <https://portswigger.net/web-security/access-control>